07/04/2026

PET361 Milestone4

Philip van Huyssteen

Khanyisile MAJOLA
602949

Table of Contents

Introduction 2
XAMPP Setup 2
Client Login Credentials 2
Database Setup 3
Database Connection 3
Login Page Clone 3
Client Login 4
SQL Injection Attack 4
Cross-Site Scripting (XSS) Attack 5
Complete Code 7
- index.php 7
- xss-demo.php 13

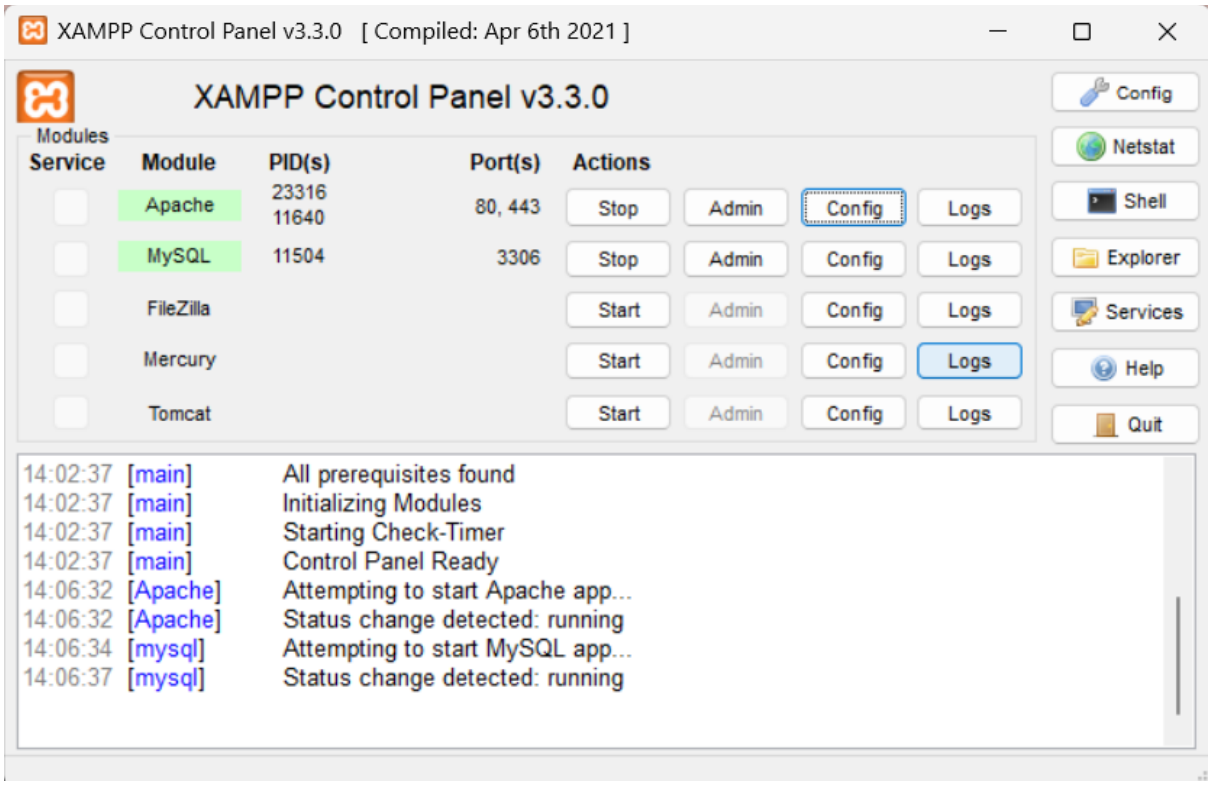
References 18

Introduction

This document presents the creation of an offline clone of AltoroMutual's sign-in page that demonstrates two common web security vulnerabilities, SQL Injection and Cross-Site Scripting (XSS). The website was built using PHP and MySQL running on XAMPP.

XAMPP Setup

XAMPP Control Panel was used to run Apache (web server) and MySQL (database). Both services are running with a green indicator



Client Login Credentials

Username	Password
jsmith	pass123
sjohnson	welcome
mwilliams	banking
ebrown	secure
djones	access

<u>SQL Injection Test:</u>

Username: ' OR '1'='1' #

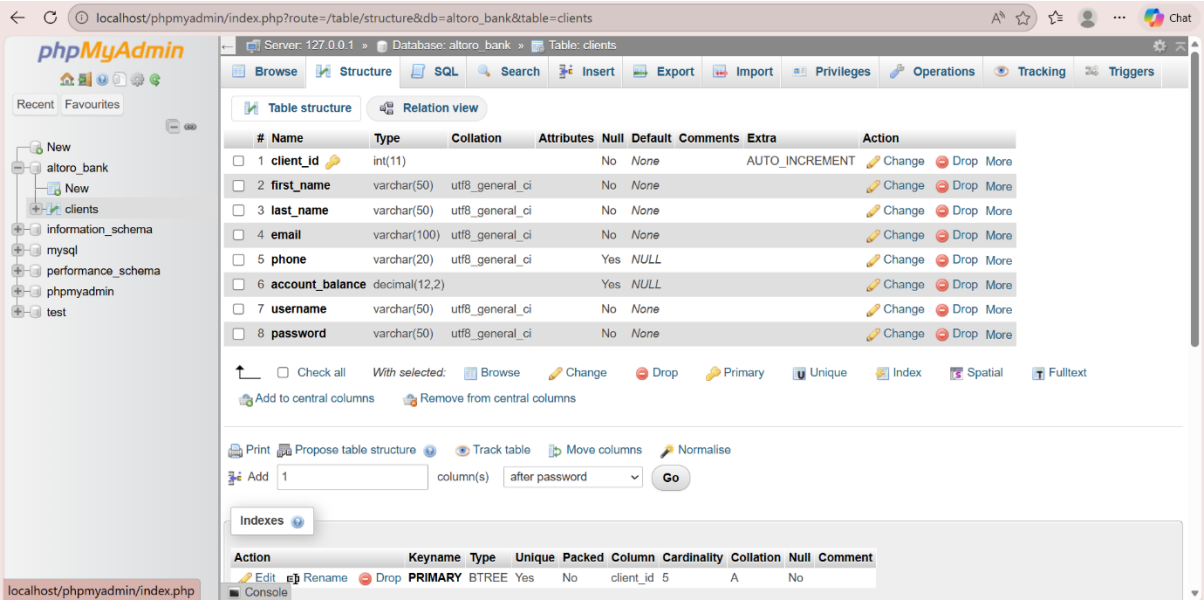
Password: (any value)

XSS Test:

Search box: <script>alert('XSS Vulnerability Found!')</script>

Database Setup

The database 'altoro_bank' was created in phpMyAdmin with a 'clients table containing 5 records and 7 fields



Database Connection

The website connects to the database using PHP's MySQLi extension

How it works:

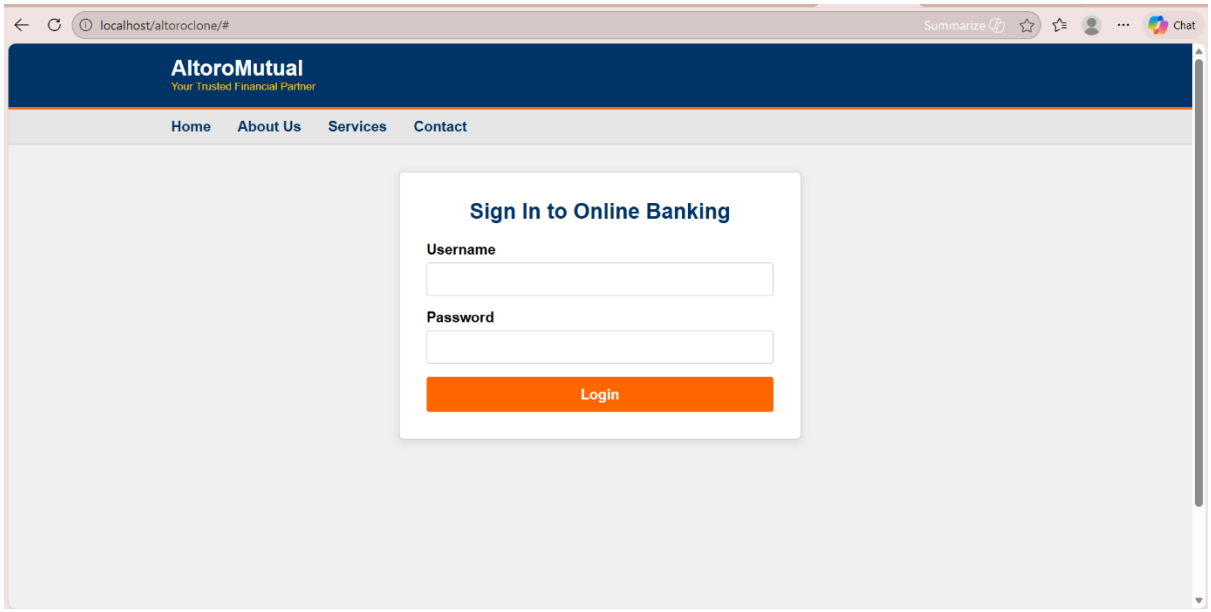
- XAMPP provides Apache web server and MySQL database
- The PHP code uses mysqli_connect() to establish connection
- Connection parameters: localhost, username "root", empty password
- Database selected: "altoro_bank"
- Queries are executed using mysqli_query()

Code used:

```
$conn = mysqli_connect("localhost", "root", "", "altoro_bank");
```

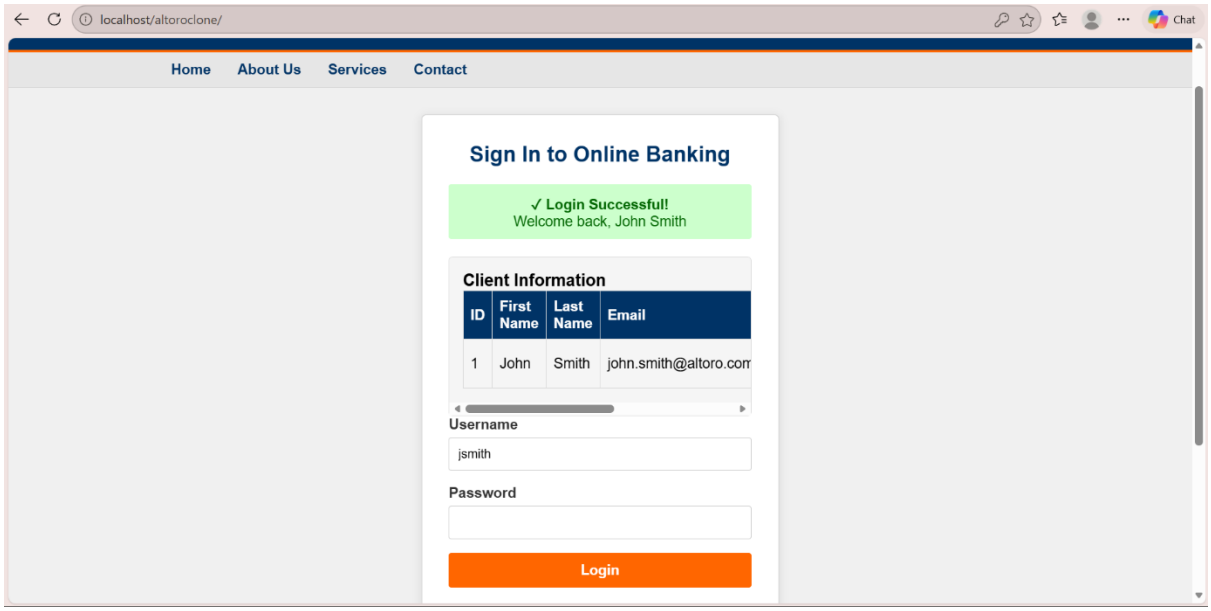
Login Page Clone

The sign-in page was cloned to look just like AltoroMutual's official login page



Client Login

This is a normal login with valid credentials that displays only the client's information



SQL Injection Attack

<u>What is SQL Injection?</u>

it is a code injection technique where an attacker inserts malicious SQL code into a query to manipulate the database. How it works is that the login page takes input and directly embeds it into the SQL query.

<u>Code:</u>

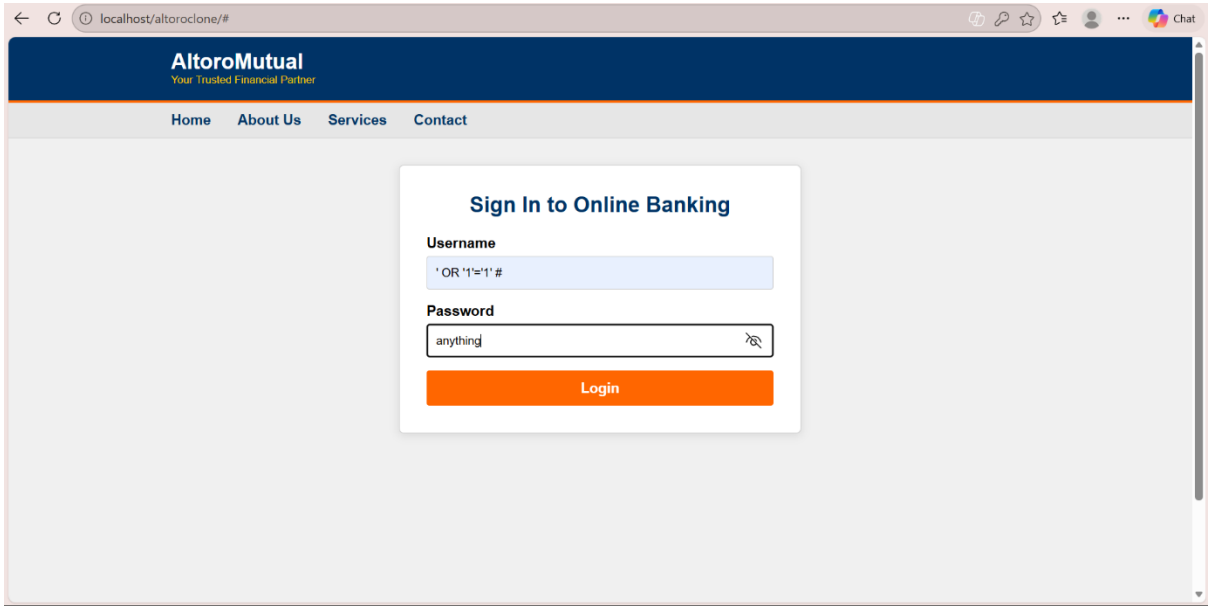
$sql = "SELECT * FROM clients WHERE username='$input_username' AND password='$input_password'";

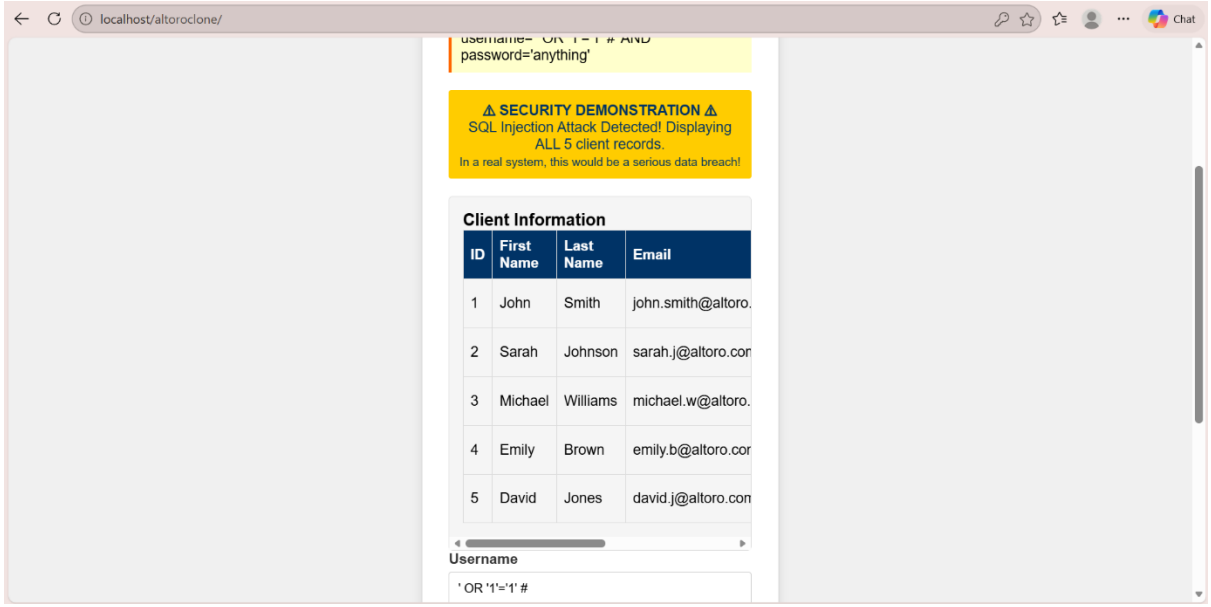
<u>The Attack:</u>

When the attacker inserts ' OR '1'='1' # as the username the query becomes:

SELECT * FROM clients WHERE username='' OR '1'='1' # AND password='anything'

The # character comments out the password check and '1'='1' is always true, so the query returns all client records





Cross-Site Scripting (XSS) Attack

<u>What is XSS?</u>

It is a vulnerability where an attacker injects malicious JavaScript code into a web page that then executes in other users' browsers. How it works is that the search page takes user input and echoes it back to the page.

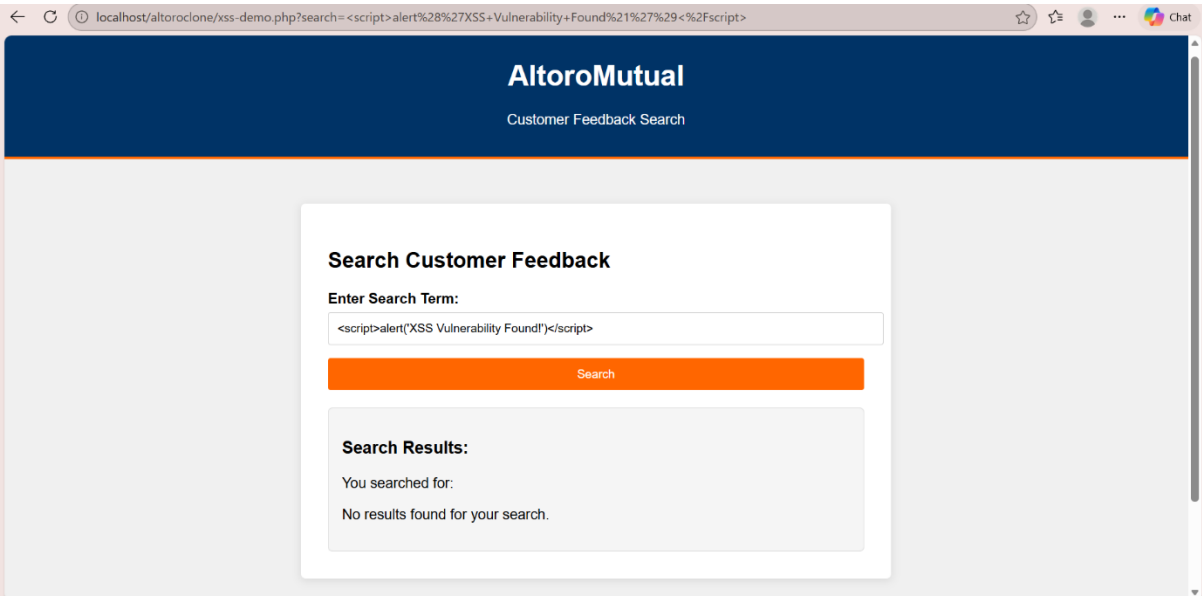
Code:

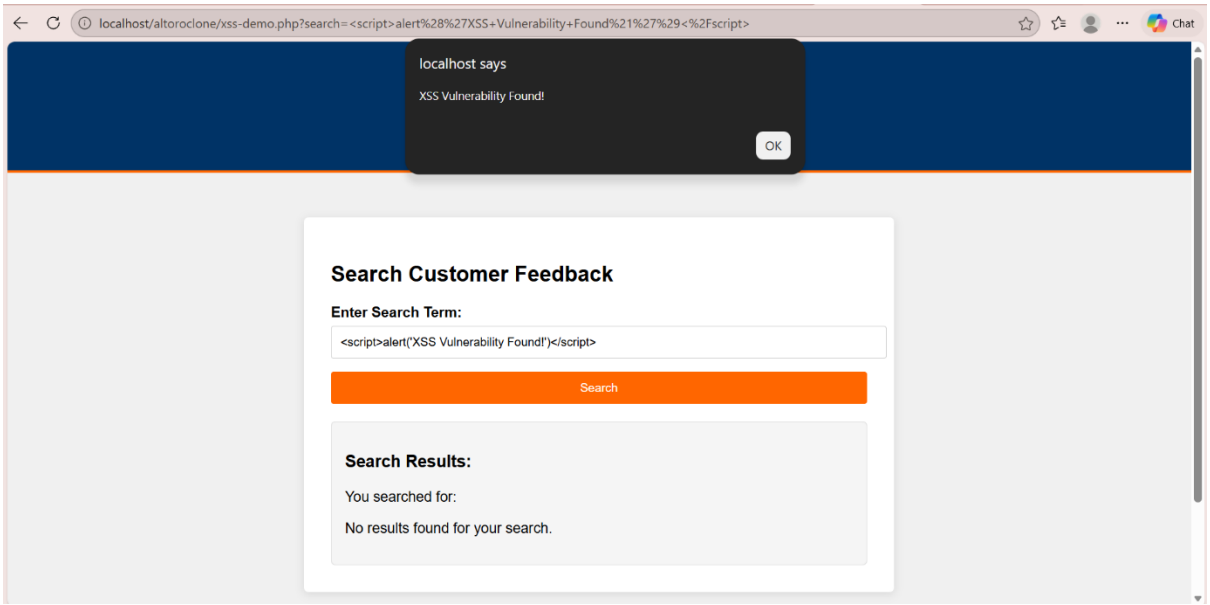
```
echo "You searched for: " . $_GET["search"];
```

The Attack:

When the attacker enters '<script>alert('XSS')</script>' in the search box, the browser interprets it as actual JavaScript code instead of plain text.

An alert popup will appear on the screen saying "XSS is found"





Complete Code

index.php

```
<?php
/**
 * AltoroMutual Offline Clone - Security Demonstration
 * Demonstrates SQL Injection and XSS vulnerabilities
 */

// Database connection
$servername = "localhost";
$username = "root";
$password = "";
$dbname = "altoro_bank";

$conn = mysqli_connect($servername, $username, $password, $dbname);

if (!$conn) {
   die("Connection failed: " . mysqli_connect_error());
}
?>

<!DOCTYPE html>
<html lang="en">
<head>
   <meta charset="UTF-8">
   <title>AltoroMutual - Online Banking</title>
   <style>
```

```
* { margin: 0; padding: 0; box-sizing: border-box; }

body { font-family: Arial, sans-serif; background-color: #f0f0f0; }

.header { background-color: #003366; color: white; padding: 15px 0; border-bottom: 3px solid #ff6600; }

.header .container { width: 960px; margin: 0 auto; display: flex; justify-content: space-between; }

.logo h1 { font-size: 24px; }

.logo p { font-size: 12px; color: #ffcc00; }

.nav { background-color: #e6e6e6; border-bottom: 1px solid #ccc; }

.nav .container { width: 960px; margin: 0 auto; }

.nav ul { list-style: none; display: flex; padding: 10px 0; }

.nav ul li { margin-right: 30px; }

.nav ul li a { text-decoration: none; color: #003366; font-weight: bold; }

.main { width: 960px; margin: 30px auto; min-height: 500px; }

.login-box { background-color: white; border: 1px solid #ccc; border-radius: 5px; width: 450px; margin: 0 auto; padding: 30px; box-shadow: 0 2px 10px rgba(0,0,0,0.1); }

.login-box h2 { color: #003366; margin-bottom: 20px; text-align: center; }

.form-group { margin-bottom: 15px; }

.form-group label { display: block; margin-bottom: 5px; font-weight: bold; }

.form-group input { width: 100%; padding: 10px; border: 1px solid #ccc; border-radius: 3px; }

.btn-login { width: 100%; padding: 10px; background-color: #ff6600; color: white; border: none; border-radius: 3px; font-size: 16px; font-weight: bold; cursor: pointer; }

.btn-login:hover { background-color: #e65500; }

.error { background-color: #ffcccc; color: #cc0000; padding: 10px; border-radius: 3px; margin-bottom: 15px; text-align: center; }

.success { background-color: #ccffcc; color: #006600; padding: 10px; border-radius: 3px; margin-bottom: 15px; text-align: center; }

.warning { background-color: #ffffcc; border-left: 4px solid #ff6600; padding: 10px; margin-bottom: 15px; }
```

```
    .results { background-color: #f5f5f5; border: 1px solid #ddd; border-radius: 5px; margin-top: 20px; padding: 15px; overflow-x: auto; }
    .results table { width: 100%; border-collapse: collapse; }
    .results th, .results td { border: 1px solid #ddd; padding: 8px; text-align: left; }
    .results th { background-color: #003366; color: white; }
    .footer { background-color: #333; color: white; text-align: center; padding: 20px; margin-top: 50px; }
  </style>
</head>
<body>
  <div class="header">
    <div class="container">
      <div class="logo">
        <h1>AltoroMutual</h1>
        <p>Your Trusted Financial Partner</p>
      </div>
    </div>
  </div>

  <div class="nav">
    <div class="container">
      <ul>
        <li><a href="#">Home</a></li>
        <li><a href="#">About Us</a></li>
        <li><a href="#">Services</a></li>
        <li><a href="#">Contact</a></li>
      </ul>
    </div>
  </div>
```

```
<div class="main">
  <div class="login-box">
    <h2>Sign In to Online Banking</h2>

    <?php
    // ==============================================================
    // SECTION 1: SQL INJECTION DEMONSTRATION
    // ==============================================================

    if ($_SERVER['REQUEST_METHOD'] === 'POST' && isset($_POST['username']) &&
isset($_POST['password'])) {
      $input_username = $_POST['username'];
      $input_password = $_POST['password'];

      // NO escaping - Direct concatenation for SQL injection to work
      $sql = "SELECT * FROM clients WHERE username='$input_username' AND
password='$input_password'";

      echo '<div class="warning"><strong>Debug SQL Query:</strong><br>' .
htmlspecialchars($sql) . '</div>';

      $result = mysqli_query($conn, $sql);

      if ($result && mysqli_num_rows($result) > 0) {
        $row_count = mysqli_num_rows($result);

        if ($row_count > 1) {
```

```
            echo '<div class="error" style="background-color:#ffcc00;
color:#003366;">';
            echo '<strong>SQL INJECTION ATTACK SUCCESSFUL</strong><br>';
            echo 'The query returned ' . $row_count . ' client records.';
            echo '</div>';
        } else {
            $user_data = mysqli_fetch_assoc($result);
            echo '<div class="success">';
            echo '<strong>Login Successful!</strong><br>';
            echo 'Welcome, ' . htmlspecialchars($user_data['first_name']) . ' ' .
htmlspecialchars($user_data['last_name']);
            echo '</div>';
        }

        echo '<div class="results">';
        echo '<h3>Client Information</h3>';
        echo '<table border="1" cellpadding="8" cellspacing="0">';
        echo '<tr style="background-color:#003366; color:white;">';
        echo '<th>ID</th><th>First Name</th><th>Last
Name</th><th>Email</th><th>Phone</th><th>Balance</th><th>Username</th>';
        echo '</tr>';

        mysqli_data_seek($result, 0);
        while ($row = mysqli_fetch_assoc($result)) {
            echo '<tr>';
            echo '<td>' . htmlspecialchars($row['client_id']) . '</td>';
            echo '<td>' . htmlspecialchars($row['first_name']) . '</td>';
            echo '<td>' . htmlspecialchars($row['last_name']) . '</td>';
            echo '<td>' . htmlspecialchars($row['email']) . '</td>';
```

```
            echo '<td>' . htmlspecialchars($row['phone']) . '</td>';
            echo '<td>$' . number_format($row['account_balance'], 2) . '</td>';
            echo '<td>' . htmlspecialchars($row['username']) . '</td>';
            echo '</tr>';
        }
        echo ' nahil';
        echo '</div>';

    } else {
        echo '<div class="error">Login Failed! Invalid credentials.</div>';
    }
}
?>

<!-- ============================================================
SECTION 2: XSS VULNERABILITY - No htmlspecialchars() on username
============================================================ -->

<form method="POST" action="">
    <div class="form-group">
        <label for="username">Username</label>
        <input type="text" id="username" name="username" required
            value="<?php echo isset($_POST['username']) ? $_POST['username'] : '';
?>">
    </div>
    <div class="form-group">
        <label for="password">Password</label>
        <input type="password" id="password" name="password" required>
```

```
            </div>
            <button type="submit" class="btn-login">Login</button>
          </form>

      </div>
    </div>

    <div class="footer">
      <p>&copy; 2024 AltoroMutual. All Rights Reserved. | Security Demonstration Only</p>
    </div>
</body>
</html>

<?php
mysqli_close($conn);
?>
```

xss-demo.php

```
<?php
// XSS Demonstration Page
?>
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <title>AltoroMutual - Search</title>
    <style>
```

```
body {
    font-family: Arial, sans-serif;
    background-color: #f0f0f0;
    margin: 0;
    padding: 0;
}
.header {
    background-color: #003366;
    color: white;
    padding: 15px 0;
    border-bottom: 3px solid #ff6600;
    text-align: center;
}
.container {
    width: 600px;
    margin: 50px auto;
    background-color: white;
    padding: 30px;
    border-radius: 5px;
    box-shadow: 0 2px 10px rgba(0,0,0,0.1);
}
.form-group {
    margin-bottom: 15px;
}
.form-group label {
    display: block;
    margin-bottom: 5px;
    font-weight: bold;
```

```
}
.form-group input {
   width: 100%;
   padding: 10px;
   border: 1px solid #ccc;
   border-radius: 3px;
}
.btn {
   width: 100%;
   padding: 10px;
   background-color: #ff6600;
   color: white;
   border: none;
   border-radius: 3px;
   cursor: pointer;
}
.result-box {
   margin-top: 20px;
   padding: 15px;
   background-color: #f5f5f5;
   border: 1px solid #ddd;
   border-radius: 5px;
}
.footer {
   background-color: #333;
   color: white;
   text-align: center;
   padding: 20px;
```

```
        margin-top: 50px;
      }
    </style>
  </head>
  <body>
    <div class="header">
      <h1>AltoroMutual</h1>
      <p>Customer Feedback Search</p>
    </div>

    <div class="container">
      <h2>Search Customer Feedback</h2>

      <form method="GET" action="">
        <div class="form-group">
          <label for="search">Enter Search Term:</label>
          <input type="text" id="search" name="search"
                 value="<?php echo isset($_GET['search']) ? $_GET['search'] : ''; ?>">
        </div>
        <button type="submit" class="btn">Search</button>
      </form>

      <?php
      // ==============================================================
      // XSS VULNERABILITY DEMONSTRATION
      // The code below echoes user input WITHOUT sanitization
      // ==============================================================
```

```
    if (isset($_GET['search']) && !empty($_GET['search'])) {
      $search_term = $_GET['search'];

      echo '<div class="result-box">';
      echo '<h3>Search Results:</h3>';
      echo '<p>You searched for: <strong>' . $search_term . '</strong></p>';
      echo '<p>No results found for your search.</p>';
      echo '</div>';
    }
    ?>
  </div>

  <div class="footer">
    <p>&copy; 2024 AltoroMutual. All Rights Reserved.</p>
  </div>
</body>
</html>
```

References

(n.d.). Retrieved from AltoroMutual: https://altoro.testfire.net/login.jsp

KirstenS. (n.d.). *Cross Site Scripting (XSS)*. Retrieved from OWASP Foundation: https://owasp.org/www-community/attacks/xss/

SQL Injection. (n.d.). Retrieved from OWASP Foundation: https://owasp.org/www-community/attacks/SQL_Injection

XAMPP Apache + MariaDB + PHP + Perl. (n.d.). Retrieved from Apache Friends: https://www.apachefriends.org/